

Employee Privacy and Data Rights Policy

Document ID: POL-PRV-018
Effective Date: January 1, 2025
Last Reviewed: September 1, 2025
Owner: Legal / People Operations
Version: 1.4

1. Purpose and Scope

This policy describes how Acme Corp collects, uses, stores, shares, and protects personal data about employees and job applicants, and what rights individuals have regarding that data.

This policy is distinct from Acme Corp's external-facing customer Privacy Policy. It applies specifically to personal data relating to employees, former employees, contractors, and job applicants.

- > Scope boundaries:
- > - Customer and business data classification and handling rules are in POL-SEC-004
- > - Monitoring of company systems is described here from the employee's perspective; the technical controls are in POL-SEC-004 §8.3
- > - Medical data collected in connection with accommodation requests is addressed in POL-DEI-014 §6.4; this policy governs how that data is retained and protected

2. Data Acme Corp Collects About Employees

2.1 Categories of Personal Data

Acme Corp collects and processes the following categories of employee personal data, depending on role and circumstances:

Category Examples	
--- ---	
Identity data	Full name, date of birth, national ID / SSN (last 4 for payroll), passport (for I-9)
Contact data	Home address, personal email, personal phone number
Employment data	Job title, level, department, manager, employment history, performance records

Compensation data	Salary, bonus, equity grants, bank account details (for payroll)
Benefits data	Health plan elections, FSA/HSA enrollment, 401(k) contributions, insurance beneficiaries
Time and attendance	Work hours, PTO balances, leave records
Technical/monitoring data	System access logs, email metadata, VPN connection logs, device usage logs
Background check data	Criminal history (where permitted), employment verification, identity verification
Medical/disability data	Accommodation requests (stored separately; see POL-DEI-014 §6.4), Workers' Comp claims
Communication data	Content of work communications (email, Slack) subject to the monitoring disclosure in Section 5

2.2 Sensitive Data

Data in the following categories is treated with heightened protection:

- Health and medical information
- Financial account details (bank accounts, SSN in full)
- Data related to protected characteristics (race, religion, sexual orientation) collected only where required for DEI reporting or accommodation purposes, with explicit consent

3. How Acme Corp Uses Employee Data

3.1 Lawful Basis

Acme Corp processes employee data on the following lawful bases under applicable privacy law (including GDPR for employees in applicable jurisdictions):

Processing Purpose	Lawful Basis
Payroll and benefits administration	Performance of employment contract
Tax reporting and compliance	Legal obligation
Background checks	Legitimate interests; employee consent where required
Performance management	Performance of employment contract; legitimate interests
Security monitoring	Legitimate interests (protecting company assets)
DEI demographic data	Employee consent (voluntary self-identification)
Emergency contact information	Employee consent

3.2 Specific Uses

Employee personal data is used for:

- Fulfilling employment contract obligations (payroll, benefits, leave administration)
- Legal and regulatory compliance (tax, labor law, OSHA, EEOC reporting)
- Company security and fraud prevention
- Business operations (access control, IT asset management)
- People analytics (aggregated, anonymized workforce insights for business planning)

Employee data is not used for:

- Selling or licensing to third parties
- Behavioral advertising
- Automated individual decision-making without human review (see POL-AIU-017 §7)

4. Data Storage and Retention

4.1 Where Employee Data Is Stored

Employee personal data is stored in the following company-managed systems:

- Workday: Core HR system of record (identity, employment, compensation, benefits, performance)
- ADP / Payroll system: Payroll processing and tax records
- Greenhouse: Candidate and hiring data
- Fidelity / Lincoln Financial / Aetna: Benefits plan data (governed by those vendors' privacy terms)
- IT Asset Management System: Equipment and access records

Data must not be stored in personal drives, unapproved cloud accounts, or consumer applications.

4.2 Retention Schedule

Employee data is retained according to the following minimum periods, after which it is securely deleted or anonymized:

| Data Category | Retention Period |

|---|---|

| Employment records (general) | 7 years after separation |

| Payroll and tax records | 7 years (IRS requirement) |

| I-9 employment verification | 3 years from hire or 1 year after separation (whichever is later) |

| Performance reviews and PIPs | 5 years after separation |

Background check results	5 years after separation
Medical/accommodation records	Duration of employment + 3 years
Candidate records (not hired)	3 years (EEOC requirement)
System/security access logs	1 year

Retention periods may be extended if the data is subject to a litigation hold or regulatory investigation. Legal issues litigation holds; data subject to a hold must not be deleted.

5. Employee Monitoring

5.1 Monitoring Disclosure

Employees have no expectation of privacy when using company-owned devices, networks, systems, or communication platforms. Acme Corp may monitor and log the following, consistent with applicable law:

- Network traffic and VPN usage
- Email metadata (sender, recipient, subject line, attachments)
- Slack and internal messaging platform activity
- Web browsing on company networks
- Application and system access logs
- Physical access card entry/exit records

5.2 Content Access

Acme Corp may access the content of work communications (email body, Slack message content, documents) only in the following circumstances:

- Investigating a reported security incident
- Responding to a legal hold or regulatory request
- Investigating a complaint of workplace misconduct
- Auditing compliance with company policies

Content access for these purposes requires approval from Legal and the CHRO, and is documented. Ad hoc browsing of employee communications by managers or IT staff is prohibited.

5.3 Personal Use on Company Systems

Employees who use company systems for incidental personal use (permitted under POL-SEC-004 §8.1) should be aware that such personal communications are subject to the same monitoring capability described in this section. Acme Corp exercises judgment in this area and does not routinely

review personal communications, but cannot guarantee their privacy.

6. Data Sharing

6.1 Internal Sharing

Employee data is shared internally on a need-to-know basis:

- Managers have access to their direct reports' employment, compensation (within their chain), and performance data
- HR Business Partners have access to data for employees in their supported groups
- Finance has access to compensation and payroll data for planning purposes
- IT Security has access to system access and security logs for all employees

6.2 External Sharing

Employee personal data is shared with third parties only in the following circumstances:

Recipient	Purpose	Data Shared
-----------	---------	-------------

---	---	---
-----	-----	-----

Payroll processor (ADP)	Payroll and tax filing	Identity, compensation, bank details
-------------------------	------------------------	--------------------------------------

Benefits providers (Aetna, Fidelity, etc.)	Plan administration	Identity, elections, beneficiaries
--	---------------------	------------------------------------

Background check provider (Checkr)	Pre-employment screening	Identity, employment history
------------------------------------	--------------------------	------------------------------

Government agencies (IRS, SSA, EEOC)	Legal and regulatory compliance	As required by law
--------------------------------------	---------------------------------	--------------------

Acquiring companies	M&A due diligence	Aggregated workforce data; individual data only post-close
---------------------	-------------------	--

Courts / law enforcement	Valid legal process (subpoena, court order)	As required by the order
--------------------------	---	--------------------------

Third-party vendors with access to employee data must have a signed Data Processing Agreement (DPA) with Acme Corp. Vendor data practices are reviewed at contract execution and annually.

6.3 Cross-Border Transfers

For employees in the European Economic Area (EEA) or other jurisdictions with cross-border transfer restrictions, Acme Corp uses appropriate transfer mechanisms (Standard Contractual Clauses or equivalent) when transferring data to Acme Corp entities or vendors outside those jurisdictions.

7. Employee Data Rights

7.1 Rights Overview

Employees (and job applicants) have the following rights regarding their personal data, subject to applicable law:

| Right | Description |

|---|---|

| Access | Request a copy of personal data Acme Corp holds about you |

| Correction | Request correction of inaccurate or incomplete personal data |

| Deletion | Request deletion of personal data where there is no lawful basis for retention (note: employment and legal obligations limit this right during and after employment) |

| Restriction | Request that processing be restricted while a correction or objection is pending |

| Data portability | Request personal data in a machine-readable format (applies to data you provided; EEA employees only) |

| Objection | Object to processing based on legitimate interests |

7.2 How to Exercise Rights

Submit data rights requests to People Operations via:

- Email: privacy@acmecorp.com
- Workday: Self-service data access requests for common data (pay stubs, PTO records, benefits elections)

Acme Corp will respond to data rights requests within:

- 30 calendar days for standard requests
- 90 calendar days for complex or voluminous requests (employee will be notified of the extension)

7.3 Limitations on Data Rights

Data deletion and restriction rights are subject to limitations where retention is required by law (tax records, I-9 forms), necessary for litigation defense, or required by a regulatory investigation. Acme Corp will specify the reason if a request is declined.

8. Data Breach Notification

If a security incident involves the unauthorized access to, or disclosure of, employee personal data, Acme Corp will:

- Notify affected employees within 72 hours of discovering the breach, where required by applicable law
- Provide information on what data was affected, likely consequences, and steps Acme Corp is taking
- Notify relevant supervisory authorities (GDPR Data Protection Authorities, state AGs) as required by applicable law

9. Contact and Questions

- Privacy Officer: privacy@acmecorp.com
- People Operations (data access requests): people-ops@acmecorp.com
- Legal (data rights, breach notification): legal@acmecorp.com
- EEA employees: Contact your regional Data Protection Representative at dpr@acmecorp.com